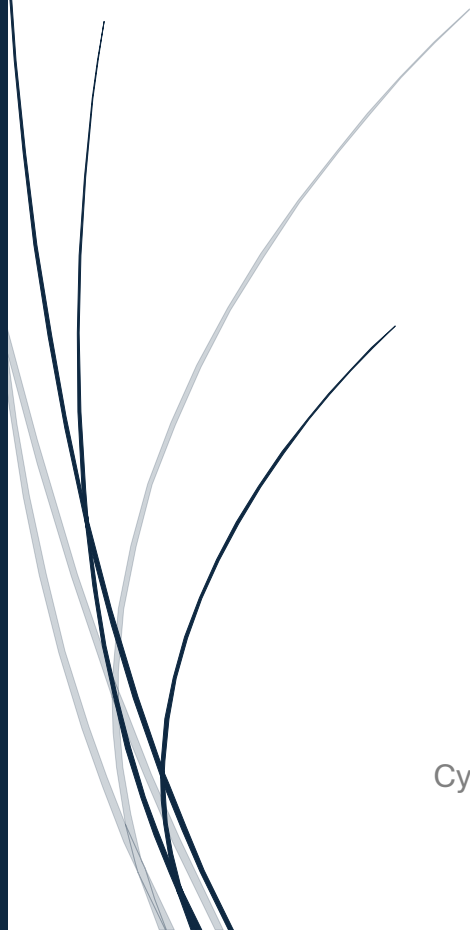


05/06/2026

Analisi Cattura di Rete

Threat Intelligence & IOC -
Cattura_U3_W1_L5.pcapng Cyber Security &
Ethical Hacking - Epicode



Lorenzo Sanna
Cyber Security & Ethical Hacking – Epicode

Host Identificati nella Cattura

La prima cosa che ho fatto aprendo la cattura su Wireshark è stata guardare quali indirizzi IP compaiono nel traffico. Ne compaiono solo due, entrambi sulla stessa subnet 192.168.200.0/24:

Ruolo	IP	MAC (parziale)	Come l'ho identificato
Vittima / Target	192.168.200.150	08:00:27:fd:87:1e	Pkt #1: annuncio BROWSER come METASPLOITABLE
Attaccante / Scanner	192.168.200.100	08:00:27:39:7d:fe	Sorgente di tutti i pacchetti SYN della scansione

Il primo elemento che mi ha permesso di identificare i ruoli è il pacchetto #1: ancora prima che parta qualsiasi scansione, il sistema **192.168.200.150** manda un annuncio NetBIOS (protocollo BROWSER) verso il broadcast **192.168.200.255** in cui si presenta con il nome **METASPLOITABLE** e lista i suoi servizi (Workstation, Server, Print Queue Server, Xenix Server, NT Workstation, NT Server...). Questo mi ha subito detto che **192.168.200.150** è la vittima, una macchina **Metasploitable**, sistema Linux intenzionalmente vulnerabile usato negli esercizi di penetration testing.

Il pannello di dettaglio in basso su Wireshark conferma inoltre che il MAC sorgente dei pacchetti SYN è **08:00:27:39:7d:fe** (attaccante .100) e il MAC destinazione è **08:00:27:fd:87:1e** (vittima .150).

Cosa ho Osservato nella Cattura

Scambio ARP (pacchetti #8-11)

Prima che partisse il traffico TCP massiccio ho notato quattro pacchetti ARP tra i due host, attorno al secondo 28.76. Guardando la colonna Source e Destination si vede chiaramente chi chiede cosa:

8	28.761629461	PCSSystemtec_fd:87:...	PCSSystemtec_39:7d:...	ARP	60	Who has 192.168.200.100? Tell 192.168.200.150
9	28.761644619	PCSSystemtec_39:7d:...	PCSSystemtec_fd:87:...	ARP	42	192.168.200.100 is at 08:00:27:39:7d:fe
10	28.774852257	PCSSystemtec_39:7d:...	PCSSystemtec_fd:87:...	ARP	42	Who has 192.168.200.150? Tell 192.168.200.100
11	28.775230099	PCSSystemtec_fd:87:...	PCSSystemtec_39:7d:...	ARP	60	192.168.200.150 is at 08:00:27:fd:87:1e

Figura 1 - pacchetti ARP

Di per sé l'ARP non è un attacco, è il normale meccanismo con cui due macchine sulla stessa LAN si scambiano i MAC address prima di comunicare via TCP. Però mi ha confermato una cosa importante: i due host sono sulla stessa rete locale, quindi l'attaccante è interno alla LAN, non esterno. Questo significa che ha già superato qualsiasi difesa perimetrale.

Il TCP SYN Port Scan (pacchetti #2 in poi)

Dal pacchetto #2 in poi l'host **192.168.200.100** inizia a mandare pacchetti TCP [SYN] verso **192.168.200.150** su porte sempre diverse. Il pattern è chiarissimo guardando la colonna Info:

2	23	764214995	192.168.200.100	192.168.200.150	TCP	74	53860	- 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522427 TSecr=0 WS=128
3	23	764287789	192.168.200.100	192.168.200.150	TCP	74	33876	- 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522428 TSecr=0 WS=128
4	23	764777523	192.168.200.100	192.168.200.150	TCP	74	80	- 53860 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294951165 TSecr=810522427 WS=64
5	23	764777427	192.168.200.100	192.168.200.150	TCP	69	443	- 33876 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
6	23	764815289	192.168.200.100	192.168.200.150	TCP	66	53860	- 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165
7	23	764899991	192.168.200.100	192.168.200.150	TCP	66	53860	- 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165

Figura 2 - pacchetti TCP fino al 7(da notare il fatto che l'attaccante chiude dopo il 7)

12	36	774143445	192.168.200.100	192.168.200.150	TCP	74	41304	- 23 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
13	36	774218116	192.168.200.100	192.168.200.150	TCP	74	56120	- 111 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
14	36	774251241	192.168.200.100	192.168.200.150	TCP	74	53876	- 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
15	36	774363051	192.168.200.100	192.168.200.150	TCP	74	53876	- 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
16	36	774495627	192.168.200.100	192.168.200.150	TCP	74	52358	- 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
17	36	774555534	192.168.200.100	192.168.200.150	TCP	74	46138	- 993 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
18	36	774614775	192.168.200.100	192.168.200.150	TCP	74	41182	- 21 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
19	36	774685505	192.168.200.100	192.168.200.150	TCP	74	23	- 41304 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535437 WS=64
20	36	774685652	192.168.200.100	192.168.200.150	TCP	74	111	- 56120 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535437 WS=64
21	36	774705050	192.168.200.100	192.168.200.150	TCP	69	443	- 33876 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
22	36	774685737	192.168.200.100	192.168.200.150	TCP	69	554	- 58636 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
23	36	774685776	192.168.200.100	192.168.200.150	TCP	69	135	- 52358 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
24	36	774760404	192.168.200.100	192.168.200.150	TCP	69	41304	- 23 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
25	36	774711972	192.168.200.100	192.168.200.150	TCP	66	56120	- 111 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
26	36	775141104	192.168.200.100	192.168.200.150	TCP	69	993	- 46138 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
27	36	775142278	192.168.200.100	192.168.200.150	TCP	74	23	- 41304 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535438 WS=64
28	36	775143445	192.168.200.100	192.168.200.150	TCP	66	41182	- 21 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
29	36	775337880	192.168.200.100	192.168.200.150	TCP	74	59174	- 113 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
30	36	775386694	192.168.200.100	192.168.200.150	TCP	74	55656	- 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
31	36	775342204	192.168.200.100	192.168.200.150	TCP	74	53860	- 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=0 WS=128
32	36	775589806	192.168.200.100	192.168.200.150	TCP	69	113	- 59174 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
33	36	775619454	192.168.200.100	192.168.200.150	TCP	66	41304	- 23 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
34	36	775654997	192.168.200.100	192.168.200.150	TCP	69	56120	- 111 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
35	36	775795938	192.168.200.100	192.168.200.150	TCP	74	22	- 55656 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535439 WS=64
36	36	775797064	192.168.200.100	192.168.200.150	TCP	74	80	- 53860 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535439 WS=64
37	36	775983786	192.168.200.100	192.168.200.150	TCP	66	55656	- 22 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466

Figura 3 - pacchetti TCP dal 12 in poi

La cosa che salta subito all'occhio è la **velocità**: tra il pacchetto #12 e il #46 passano circa 1-2 millisecondi, durante i quali vengono sondati oltre 30 porte diverse. Questo è fisicamente impossibile da fare a mano, è chiaramente uno strumento automatizzato come **Nmap**.

Nella maggior parte dei casi la vittima risponde con **[RST, ACK]** (porta chiusa). Ma in alcuni casi, come sulla porta 80 ai pacchetti #4 risponde con **[SYN, ACK]**, cioè la porta è aperta. Questa è esattamente l'informazione che interessa all'attaccante.

Perché si chiama SYN scan "stealth"

Ho notato un dettaglio interessante guardando i pacchetti #4-7: quando la vittima risponde con **[SYN, ACK]** sulla porta 80 (porta aperta), l'attaccante non completa il three-way handshake ma manda subito un **[RST]** per chiudere la connessione. Questo è il comportamento tipico della SYN scan half-open di Nmap (-sS).

Il vantaggio per l'attaccante è che non completando mai la connessione TCP, molti sistemi di logging applicativo non registrano l'evento. Il server web ad esempio non logga una connessione che non si è mai aperta completamente. Lascia meno tracce rispetto a una connessione normale.

Ipotesi sul Vettore di Attacco

Guardando tutti questi elementi insieme, la conclusione finale che mi son fatto è abbastanza chiara: **192.168.200.100** sta usando **Nmap con SYN scan (-sS)** per mappare le porte aperte di Metasploitable (**192.168.200.150**). Il comando probabilmente usato è:

```
nmap -sS 192.168.200.150 oppure nmap -sS -p- 192.168.200.150
```

Questa è la fase di **ricognizione attiva** - l'attaccante non ha ancora sfruttato nessuna vulnerabilità, sta solo raccogliendo informazioni su quali servizi sono esposti. Il passo successivo logico sarebbe scegliere una delle porte aperte trovate e tentare un exploit. Su Metasploitable le vulnerabilità più note sono sulla porta 21 (vsftpd 2.3.4 backdoor), porta 445 (Samba), porta 6667 (UnrealIRCd backdoor) e porta 80 (DVWA).

Riflessioni Personali

Questo esercizio mi ha aiutato a capire concretamente cosa significa analizzare una cattura di rete alla ricerca di IOC. All'inizio aprire Wireshark con centinaia di pacchetti può sembrare caotico, ma una volta che si sa cosa cercare, i flag TCP, la velocità dei pacchetti, chi parla con chi, il pattern diventa leggibile abbastanza in fretta.

La cosa che mi ha sorpreso di più è stata il pacchetto #1: ancora prima che iniziasse qualsiasi scansione, la vittima si era già "presentata" da sola con il suo nome host e la lista dei servizi esposti, semplicemente mandando un annuncio broadcast di routine. Non serve neanche fare una scansione per sapere che esiste e cosa gira sopra, basta stare in ascolto sulla rete. Questo mi ha fatto capire concretamente il concetto di information minimization.

Ho anche apprezzato il dettaglio della SYN scan stealth: non avevo mai capito bene perché si chiami "stealth" finché non l'ho vista nei pacchetti #4-7, l'attaccante riceve il SYN,ACK dalla porta 80, manda subito un RST e non completa mai il handshake. Sulla carta suona astratto, sui pacchetti è chiarissimo.

Una difficoltà che ho avuto inizialmente è stata identificare correttamente i ruoli dei due host. Guardando solo i pacchetti TCP con i RST sembrava che .150 fosse l'attaccante perché mandava le risposte di reset. Solo leggendo con attenzione il pacchetto #1, l'annuncio BROWSER con il nome METASPLOITABLE, ho capito che .150 era la vittima e .100 l'attaccante. Questo mi ha insegnato a leggere sempre tutta la cattura dall'inizio prima di trarre conclusioni.

Conclusione

In sintesi, la cattura mostra un **TCP SYN Port Scan** condotto da **192.168.200.100** (attaccante) verso **192.168.200.150** (Metasploitable, vittima). Gli IOC principali sono: l'annuncio NetBIOS del pacchetto #1 che rivela l'identità della vittima, le centinaia di SYN su porte diverse in pochi millisecondi, le risposte RST,ACK che confermano la scansione, la porta 80 trovata aperta, e lo scambio ARP che dimostra che l'attaccante è interno alla LAN.

La fase osservata è quella di ricognizione attiva, l'attaccante non ha ancora sfruttato nessuna vulnerabilità, ma ha già una mappa dei servizi esposti.